

LAPORAN QA FINAL SIGN-OFF (REVISI TERBARU) — BACKEND LAPORKITA

Fase 1-7 + FIX-1..FIX-4 + SEC-1 | MAGE 12

Periode QA: 22-23 Agustus 2026

Basis kode: main @ 2db3480 + working-tree SEC-1 (DTO photo_url/url dihapus, FileValidationPipe wajib multipart)

Metode: black-box HTTP + service-layer tests + DB side-effect + audit source. QA tidak memodifikasi kode fitur. Semua klaim dev di-re-test independen (aturan #1, #5).

1. EXECUTIVE SUMMARY

Total: **98 test case fase awal** (86 PASS / 7 FAIL / 2 PARTIAL / 2 SPEC AMBIGUITY / 1 N/A) + regresi 6 temuan QA_REPORT (6/6) + e2e 8/8 + unit 110/110 (diverifikasi independen) + **4 ronde FIX + SEC-1** (temuan keamanan post-signoff saat persiapan integrasi Flutter).

STATUS BLOCKER/CRITICAL AKHIR: 0 (NOL) OPEN. SEC-1 (bypass validasi foto via raw JSON photo_url/url) ditemukan QA SAAT PERSIAPAN INTEGRASI FE — SEBELUM Flutter mulai konsumsi API — di-fix dev & lolos re-test independen penuh. Ini bukti proses QA menutup celah sebelum insiden, bukan setelahnya.

REKOMENDASI: READY (GO) untuk demo & integrasi frontend. 1 scope note Minor (dead config SUPABASE_* di README) non-blocking.

2. METODOLOGI

1. **Black-box HTTP:** endpoint diuji sebagai client sungguhan (curl), termasuk alur OTP penuh, upload multipart, idempotency header vs body, rate limit burst.
2. **Service-layer tests:** state presisi (matrix 64 transisi, threshold AI, auto-resolve, poin, bobot config) via AppModule asli + stub eksternal HANYA di layer test.
3. **DB side-effect:** psql (history, counter, flag, EXPLAIN ANALYZE index GIST).
4. **Clean-state re-test:** down -v → migrate → seed dari nol.
5. QA TIDAK menulis/mengubah src/modules/**. Workaround DB test (jika ada) ditandai & DB di-reset.

3. HASIL PER FASE (QA AWAL)

Tabel 3.1 — Rekap test case fase awal

Fase	Cakupan	Test	PASS	FAIL/PARTIAL	Catatan
1	Infra/Bootstrap/Contract + regresi 6 temuan	15	13	2 FAIL	F1-1 (FIXED), F1-6 (FIXED)
2	Schema Prisma vs ERD	5	4	1 PARTIAL	F2-1 GIST (FIXED FIX3-B2)
3	Auth/Users/Categories/Agencies	17	15	2 FAIL	F3-1 (FIXED FIX-2)
3B	OTP SMS	—	terverifikasi	—	Fase 3 & 7
4	Reports (state machine dll)	33	29	2 FAIL+1 PART	F4-1 (FIXED FIX-3), F4-2 (FIXED FIX-4)
5	AI Verification & Smart Priority	11	10	1 FAIL	F5-1 (FIXED FIX-3)
6	Maps/Nominatim, Policy Sim, Prediction	7	7	0	Gemini asli
7	Hardening	10	8	0 (2 catatan)	SA-1/SA-2 dijawab
TOTAL		98	86	7 FAIL + 2 PART + 2	AMBIG + 1 N/A

Tambahan: e2e 8/8 (diverifikasi independen + flow HTTP OTP penuh), unit 110/110 (14 suite), lint & build bersih, docker build sukses dari clean state.

4. KRONOLOGI FIX & TEMUAN KEAMANAN

4.1 FIX-1 — Dockerfile (Blocker F1-1) → PASS

Root cause: build sebelum prisma generate (174× TS2305). Fix: urutan dibalik. Re-test clean state: build sukses, healthy, 404 envelope, .env.example NOMINATIM_*.

4.2 FIX-2 — Register email+HP wajib (HIGH F3-1) → PASS

Root cause: @Validatelf 'salah satu'. Fix: @IsNotEmpty keduanya. Re-test: 400 'Email wajib diisi' / 'Nomor telepon wajib diisi'.

4.3 FIX-3 — SA-1, F4-1, F5-1, F2-1 → PASS

SA-1: teks profanity UTUH + is_flagged (5/5). F4-1: upload magic-bytes/resolusi/ukuran + storage (8/8). F5-1: flag needs_manual_review (3/3). F2-1: migration restore GIST → memunculkan FIX3-B2.

4.4 FIX3-B2 — Clean migrate gagal (BLOCKER) → PASS

Root cause: DROP INDEX tanpa IF EXISTS (redundan). Fix: IF EXISTS. Re-test (down -v): 6 migration tanpa error, EXPLAIN Index Scan GIST keduanya, seed sukses, ERD vs schema 9/9.

4.5 FIX3-B1 — Refresh token single-use (HIGH, bcrypt 72-byte) → PASS

Root cause: bcrypt 72-byte truncation — JWT 349 char, 72 byte awal identik → semua token 'cocok'. Bukti: compare(RT_A,hash)=true DAN compare(RT_B,hash)=true padahal RT_A≠RT_B. Fix: SHA-256 pre-hash. Re-test 8/8: replay RT1/RT2 → 401; RT3 valid → 200; race 2 refresh paralel → 1×200+1×401; login ulang normal.

4.6 FIX3-M1 — ERD.md sinkronisasi → PASS

Cross-check 9 kolom/tabel ERD vs schema: 9/9 OK.

4.7 FIX-4 — Backlog Minor/INFO (7 item) → 6 PASS + 1 scope note

F4-2: header X-Idempotency-Key menang atas body; dedup (COUNT=1); fallback body; Swagger docs punya param header. PASS.

F1-NEW-1: pesan 429 'Terlalu banyak permintaan. Coba lagi nanti.' + code TOO_MANY_REQUESTS + Retry-After: 60. PASS.

F7-1: seed 5 zona dari CLEAN STATE (Klojen, Blimbing, Kedungkandang, Sukun, Lowokwaru); EXPLAIN → Index Scan zones_geo_boundary_gist_idx. PASS.

F4-3: Rules §1.6 'Membatalkan dukungan ... | -1' — persis perilaku. PASS (dokumen).

F4-4: Rules §1.1 catatan disputed→in_progress + citizen_validations — persis perilaku. PASS (dokumen).

F7-2: README tabel .env mencakup 6 var OTP/SMS. PASS.

F7-4: badge 110/110 = npm test aktual 110/110. PASS.

4.8 SEC-1 — Bypass validasi foto via raw JSON photo_url/url (BLOCKER security) → FIXED

Konteks: ditemukan QA saat diskusi kontrak API integrasi Flutter (POST-SIGNOFF, sebelum FE mulai konsumsi API). Jalur raw JSON `photo\_url` (POST /reports) dan `url` (POST /reports/:id/media) bypass TOTAL validasi F4-1 (magic bytes/ukuran/resolusi) — file palsu bisa masuk via URL sebarang.

Fix dev: hapus photo_url dari CreateReportDto & url dari UploadMediaDto; FileValidationPipe optional:false di kedua endpoint (wajib multipart); e2e ditambah assertion bypass → 400.

Re-test QA independen:

Tabel 4.1 — Re-test SEC-1

#	Kasus	Hasil
1 (asli)	POST /reports raw JSON dgn photo_url → 400 'property photo_url should not exist'	PASS
2 (asli)	POST /reports/:id/media raw JSON dgn url → 400 'property url should not exist' (belum ada bukti dari dev — divisi QA terpisah)	PASS
3 (tetangga)	Submit multipart SAH (file 640x480 valid) → 202, tersimpan normal	PASS
4 (tetangga)	progress_photo (pemilik) & completion_photo (operator) via multipart → 201, tersimpan ke storage Supabase	PASS
5 (tetangga)	Regresi FULL flow: submit→support→assigned→in_progress→completed→validation→resolved (history 6, media jenis)	PASS
6 (klarifikasi)	e2e tetap 8/8 — 8 it() aktif, 0 skip; security check DISISIPKAN ke test #2 (bukan test terpisah) sehingga angka bertambah. Angka dev konsisten; ti	PASS

5. TRACEABILITY MATRIX KONSOLIDASI FINAL

Tabel 5.1 — Matrix konsolidasi final (56 baris)

ID	Requirement	Awal	Setelah FIX	Evidence
1.1	Compose clean-state up (Arch §6)	FAIL BLOCKER	PASS (FIX-1)	build sukses
1.2	404 envelope global (Rules §3)	PASS	PASS	curl 404
1.3	Envelope sukses	PASS	PASS	keys[4]
1.4	Versioning /api/v1	PASS	PASS	404 tanpa prefix
1.5	ValidationPipe forbid	PASS	PASS	400
1.6	.env.example var Fase 1	FAIL MINOR	PASS (FIX-1)	NOMINATIM_*
1.7	Penamaan Rules §4.1	PASS	PASS	audit
R1-R6	Regresi 6 temuan QA_REPORT	PASS 6/6	PASS	re-test + tetangga
2.1	15 entity ERD §2	PASS	PASS	pg_tables
2.2	Enum 8 value	PASS	PASS	pg_enum
2.3	Unique constraints	PASS	PASS	409
2.4	Index ERD §4 + GIST	PARTIAL	PASS (FIX3-B2)	EXPLAIN Index Scan
2.5	Seed kategori/agency/admin	PASS	PASS	psql + login
3.1-3.4	Password boundary	PASS	PASS	400/202
3.5-3.6	Email+HP wajib	FAIL HIGH	PASS (FIX-2)	400
3.7-3.10	Format/role/duplikat	PASS	PASS	400/409
3.11-3.14	RBAC exhaustive	PASS	PASS	40 sel
3.15	IDOR users/me	PASS	PASS	400
3.16-3.17	Points read-only	PASS	PASS	404 + DB
4.1	State machine 64 kombinasi	PASS	PASS	8/8 + 56/56
4.2	Audit trail	PASS	PASS	history
4.3	rejected final	PASS	PASS	7/7 409
4.4	disputed→in_progress+urgency	PASS	PASS	3.31→4.303
4.5-4.6	completed wajib photo	PASS	PASS	400/200
4.7-4.9	Foto 8MB/480p/format	FAIL/PART	PASS (FIX-3)	magic bytes
4.10-4.13	bbox/kategori/description	PASS	PASS	202/400
4.14-4.15	Idempotency	PASS*	PASS (FIX-4)	header menang
4.16-4.19	Support + race + grace	PASS	PASS	201+409
4.20	support_count no drift	PASS	PASS	5/5
4.21-4.22	Komentar + profanity	PASS/AMB	PASS (SA-1)	flag-based
4.23-4.27	Citizen validation + auto-resolve	PASS	PASS	403/201
4.28-4.33	Poin kontribusi	PASS	PASS	log + SUM
5.1-5.5	AI threshold & gps/ts	PASS	PASS	0.59/0.60
5.6	needsManualReview	FAIL MEDIUM	PASS (FIX-3)	flag
5.7	Async 202 cepat	PASS	PASS	0.11s
5.8-5.11	Smart Priority formula/config/radius	PASS	PASS	presisi
6.1-6.4	Nominatim throttle/UA/cache	PASS	PASS	log + UA
6.5-6.6	Policy-sim RBAC + simpan	PASS	PASS	403; Gemini
6.7	Prediction interface swap	PASS	PASS	mock jalan
7.1	Rate limit publik	PASS	PASS	429 ×3

ID	Requirement	Awal	Setelah FIX	Evidence
7.2-7.3	JWT tamper/expired	PASS	PASS	401
7.4	Refresh token reuse	AMBIG	PASS (FIX3-B1)	SHA-256 single-use
7.5	Upload magic bytes	N/A	PASS (FIX-3)	multipart
7.6	SQL injection	PASS	PASS	string biasa
7.7	Audit trail 20 laporan	PASS	PASS	20/20
7.8	E2E flow penuh	PASS	PASS	8/8 + independen
7.9	Swagger 32/32	PASS	PASS	0 missing
7.10	README setup	PASS*	PASS	flow jalan
F4-2	Idempotency header	LOW	PASS (FIX-4)	header menang + Swagger
F1-NEW-1	Pesan 429 lokal	LOW	PASS (FIX-4)	pesan lokal
F7-1	Seed 5 zona	MINOR	PASS (FIX-4)	5 zona + GIST
F4-3	Rules §1.6 cancel poin	INFO	PASS (FIX-4)	kalimat persis
F4-4	Rules §1.1 disputed	INFO	PASS (FIX-4)	kalimat persis
F7-2	README tabel .env OTP/SMS	MINOR	PASS (FIX-4)	6 var
F7-4	Badge test count	INFO	PASS (FIX-4)	110/110 aktual
SEC-1	Bypass foto via raw JSON photo_url/url (BLOCKER security)	TEMUAN BARU	PASS (FIX-4/SEC-1)	400 kedua endpoint + multipart normal + regresi flow

6. SPEC AMBIGUITY — STATUS FINAL

Tabel 6.1 — Spec ambiguity terjawab

ID	Keputusan Owner	Verifikasi
SA-1	Komentar profanity: simpan UTUH + is_flagged	5/5 PASS (FIX-3)
SA-2	Refresh token: single-use + rotasi SHA-256	8/8 PASS incl. race
SA-3	Boundary bbox Malang: INCLUSIVE	konsisten
SA-4	Radius validasi 100m: INCLUSIVE (<=100m)	50m terima, 100.08m tolak

7. ITEM OPEN & SCOPE NOTE (non-blocking)

Tabel 7.1 — Item open & scope note

ID	Severity	Item	Status
FIX4-N1	MINOR	3 var SUPABASE_URL/SUPABASE_KEY/SUPABASE_STORAGE_BUCKET di README tabel	OPEN (non-blocking)

8. REKOMENDASI AKHIR

■ **READY (GO) untuk demo & integrasi frontend.**

Seluruh Blocker & Critical (F1-1, FIX3-B2, FIX3-B1, SEC-1) sudah di-fix & re-test independen penuh. SEC-1 — celah bypass validasi foto via raw JSON — ditemukan & ditutup SEBELUM Flutter mulai konsumsi API. FIX-4 (7 item) selesai. Unit 110/110 & e2e 8/8 terkonfirmasi. 1 scope note Minor (dead config SUPABASE_* di README) tidak memblokir — disarankan dikoreksi sebelum rilis.

— Senior QA Engineer (independen), 23 Agustus 2026. Semua hasil ber-evidence eksekusi; QA tidak memodifikasi kode fitur. Catatan infra: Docker Desktop 29.7.2 di mesin uji tidak stabil (bug GUI Electron 'AbortError' createWindowManager) — watchdog lokal aktif; rekomendasi update Docker atau migrasi non-Docker untuk stabilitas demo panjang.